

Audit de Conformité et Référentiels (ANSSI, CIS)

Partie 1 : Cible Linux - Audit automatisé avec Lynis

1.1 Déploiement et exécution du scan

```
sudo apt-get update && sudo apt-get install lynis -y  
sudo lynis audit system
```

1.2 Analyse du rapport de conformité

- **Quel est le score final obtenu ("Hardening index" sur 100) par votre machine ?**
 - *Résultat attendu* : Le score varie légèrement selon la version exacte de la distribution de base fournie par l'infrastructure, mais il se situe généralement autour de **55 à 65 / 100** pour une installation Debian/Ubuntu standard non durcie.

Extraction des alertes (warnings) depuis le journal :

```
grep -i warning /var/log/lynis.log
```

- - *Exemples de warnings typiques à commenter* : Absence de pare-feu actif, détection de comptes sans mot de passe, ou compilateurs présents sur un environnement de production.

1.3 Vérification manuelle de la conformité (Focus ANSSI)

```
grep ENCRYPT_METHOD /etc/login.defs
```

- *Résultat attendu* : **ENCRYPT_METHOD YESCRYPT** (ou **SHA512**).
- *Point de débriefing* : Rappeler que si le résultat renvoyait **MD5** ou **DES**, le système serait considéré comme hautement vulnérable et non conforme aux exigences minimales de l'ANSSI.

Partie 2 : Cible Windows - Audit et Durcissement (Guide

d'Hygiène ANSSI)

2.1 État des lieux de la politique actuelle

net accounts

- **Quelle est la longueur minimale actuellement exigée pour un mot de passe ?**
 - *Résultat attendu* : Par défaut sur un Windows Server autonome, c'est généralement **0** (aucune limite) ou **7** caractères.
- **Combien de mots de passe sont mémorisés dans l'historique par défaut ?**
 - *Résultat attendu* : **0** (Aucun historique, l'utilisateur peut remettre indéfiniment `P²ssw0rd`).

2.2 Extraction et analyse du fichier de sécurité

Export de la configuration brute

```
secedit /export /cfg C:\secpol.inf
```

Lecture filtrée via PowerShell

```
Get-Content C:\secpol.inf | Select-String "PasswordHistorySize"
```

- *Résultat attendu* : La console retourne `PasswordHistorySize = 0`.
- *Point de débriefing* : Montrer que l'audit peut être automatisé : un script PowerShell pourrait vérifier cette variable sur 500 serveurs sans jamais ouvrir d'interface graphique.

2.3 Remédiation : Alignement sur le référentiel ANSSI

Application immédiate des recommandations (10 mots de passe mémorisés, 90 jours max, 14 caractères min)

```
net accounts /uniquepw:10
```

```
net accounts /maxpwage:90
```

```
net accounts /minpwlen:14
```

Validation de la bonne prise en compte

```
net accounts
```

- *Animation du débriefing* : Faire remarquer aux stagiaires que ces commandes modifient instantanément la stratégie. **Cependant**, précisez bien que si ce serveur était intégré à un domaine Active Directory, ces réglages locaux seraient impitoyablement écrasés par la *Default Domain Policy* (GPO) du contrôleur de domaine toutes les 90 minutes. Sur un domaine, c'est la GPO qui dicte la loi, pas le registre local.